

[웹 해킹 원리 과제]

[400]

헤더에 메소드를 지워서, 잘못된 요청을 하도록 수정하였습니다.

```
1 / HTTP/1.1
2 Host: webhacking.kr:10022
3 Cache-Control: max-age=0
4 Accept-Language: ko-KR,ko;q=0.9
```

400 Error!

your key : KEY{10fac9b9f4112a1d9a650fec275bf164}

[403]

1. 깃발 그림이 있는 것을 확인하고, 페이지 소스를 확인해보았습니다.
2. flag.png 파일이 /img 디렉토리에 있는 것을 확인했습니다.

```
<img src=/img/flag.png><form>
Key1 : <input name=key1 size=40 pattern='KEY{([0-9]|[a-f]){32}}'
Key2 : <input name=key2 size=40 pattern='KEY{([0-9]|[a-f]){32}}'
Key3 : <input name=key3 size=40 pattern='KEY{([0-9]|[a-f]){32}}'
```

3. 그래서 디렉토리 목록에 접근하도록 요청을 수정했습니다.

```
1 GET /img/ HTTP/1.1
2 Host: webhacking.kr:10022
3 Cache-Control: max-age=0
```

4. 접근 금지되었습니다.

403 Error!

your key : KEY{cd79de80772c1873bcf63e41e3379c6f}

[404]

url을 수정해서, 아예 없는 페이지로 이동하려고 했습니다.

```
1 GET /asdf HTTP/1.1
2 Host: webhacking.kr:10022
3 Accept-Language: ko-KR,ko;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
```

404 Error!

your key : KEY{23c0b3a9ccc44b72f17a99eadb351d2f}

[405]

1. TRACE 메소드는 웹 서버로 가는 네트워크 경로를 체크하는 Method입니다.
2. 보안 문제로 해당 메소드를 허용하지 않는 경우가 많다고 하여 GET 메소드를 TRACE 메소드로 수정했습니다.

```
1 TRACE / HTTP/1.1
2 Host: webhacking.kr:10022
3 Cache-Control: max-age=0
4 Accept-Language: ko-KR,ko;q=0.9
```

405 Error!

your key : KEY{e5602408f2037c05bbbb0995fec6bc58}

[408]

1. 불완전한 상태로 요청을 보내서 요청 시간을 초과하도록 수정하였습니다.
2. 신기한 건, 408에러를 띄우다가 다시 시도했을 때 정상적으로 페이지가 보이는 경우가 종종 있었습니다.

```
GET / HTTP/1.1
Host: webhacking.kr:10022
Cache-Control: max-age=0
Accept-Language: ko-KR,ko;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/135.0.0.0 Safari/537.36
Accept: text/html,

image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Connection: close
```

408 Error!

your key : KEY{e44fa3e1865a3839cbc0b658f1ae08cf}

[414]

쿼리 스트링에 파라미터를 많이 추가해서 URI를 길게 만들었습니다.

```
KEY%7B23c0b3a9ccc44b72f17a99eadb351d2f%7D&key4=
KEY%7B23c0b3a9ccc44b72f17a99eadb351d2f%7D&key5=
KEY%7B23c0b3a9ccc44b72f17a99eadb351d2f%7D&key6=
KEY%7B23c0b3a9ccc44b72f17a99eadb351d2f%7D&key7=
```

Request attributes	2	▼
Request query parameters	778	▼

414 Error!

your key : KEY{d1617527ac2143863bc347c6123ed921}

[결과]

Key1 :

Key2 :

Key3 :

Key4 :

Key5 :

Key6 :

Key7 :

Key8 :

Your score : 6

FLAG is WHS{aprilFoolsDay}

[과제 후기]

처음엔 화이트햇 스쿨 취약점 분석 파트를 보면서, python에서 request를 이용해 400번대 에러가 출력되도록 하려고 했으나, 정말 어렵도 없어서, Burp Suite를 이용했습니다.

이번 과제를 하면서 클라이언트와 서버가 어떤 방식으로 소통하는지에 익숙해졌고, 클라이언트의 요청 구문이 어떤 식으로 구성되어 있는지, 그리고 그 표현에 대해서 적응할 수 있는 좋은 기회였습니다.

그리고 http 응답 상태에 대해서 어떤 걸 참고할 수 있는지에 대한 정보도 얻었고, 적어도 앞으로 제가 만들어낸 400번대 오류는 어떤 경우에 일어날 수 있는지 확실히 기억할 것 같습니다. 감사합니다.